



Counterintelligence in Red Teaming using MITRE ENGAGE in 15min

OWASP Meetup Frankfurt #51, Oct 27th 2021

Who am I



Johannes Schönborn

Penetration Testing since 2006
2016 Founded Exploit Labs
@johnny_sec, @xpltlabs

OWASP Frankfurt

ENISA's Ad-Hoc Working Group on Cyber
Threat Landscapes

johannes@exploitlabs.de

APT “Happy Turtle”

- Targets Power Plants PP
- Wants to disrupt
- Knows Robby is an OT Op
- Knows PP uses certain tech
- Knows PP uses cool WebApp OT



Who we are

Agenda

1. How We Attack: MITRE ATT&CK
2. How Enterprises Can Defend: MITRE Engage
3. Adjusted Red Team Attack Playbooks
4. Key Takeaways



1. How We Attack: MITRE ATT&CK

1. How We Attack: MITRE ATT&CK

Privilege Escalation		Defense Evasion		Credential Access		Discovery		Lateral Movement		Collection	
13 techniques		39 techniques		15 techniques		27 techniques		9 techniques		17 techniques	
on (4)		Abuse Elevation Control Mechanism (0/4)		Brute Force (2/4)	Credential Stuffing	Account Discovery (0/4)		Exploitation of Remote Services	Archive Collected Data (0/3)		
	Create Process with Token	Access Token Manipulation (1/5)	Create Process with Token		Password Cracking	Application Window Discovery	Internal Spearphishing	Audio Capture			
	Make and Impersonate Token		Make and Impersonate Token		Password Guessing	Browser Bookmark Discovery	Lateral Tool Transfer				
	Parent PID Spoofing		Parent PID Spoofing		Password Spraying	Cloud Infrastructure Discovery	Remote Service Session Hijacking (0/2)		Clipboard Data		
	SID-History Injection		SID-History Injection		Credentials from Password Stores (0/5)	Cloud Service Dashboard	Remote Services (0/6)		Data from Cloud Storage Object		
	Token Impersonation/Theft		Token Impersonation/Theft		Exploitation for Credential Access	Cloud Service Discovery	Replication Through Removable Media		Data from Configuration Repository (0/2)		
	Active Setup		BITS Jobs		Forced Authentication	Container and Resource Discovery	Software Deployment Tools		Data from Information Repositories (1/2)		
	Authentication Package		Build Image on Host		Forge Web Credentials (0/2)	Domain Trust Discovery	Taint Shared Content		Confluence		
	Kernel Modules and Extensions		Deobfuscate/Decode Files or Information		Deobfuscate/Decode Files or Information (T1140)	File and Directory Discovery	Application Access Token		Sharepoint		
	LSASS Driver		Deploy Container		Score: 1	Network Service Scanning	Pass the Hash				
Plist Modification	Direct Volume Access		Comment: An [APT28] (https://attack.mitre.org/groups/G0007) macro uses the command certutil -decode to decode contents of a .txt file storing the base64 encoded payload. (Citation: Unit 42 Sofacy Feb 2018) (Citation: Palo Alto Sofacy 06-2018)	Network Share Discovery	Pass the Ticket						
Port Monitors	Domain Policy Modification (0/2)	Output capture (1/4)	Network Sniffing	Web Session Cookie							
Print Processors	Execution Guardrails (0/1)	Man-in-the-Middle (0/2)	Peripheral Device Discovery								
Re-opened Applications	Exploitation for Defense Evasion	Modify Authentication Process (0/4)	Permission Groups Discovery (0/3)								
Registry Run Keys / Startup Folder		Network Sniffing	Process Discovery								
Security Support Provider		OS Credential Dumping (1/8)	Query Registry								
		Hidden File System	Remote System Discovery								
		Hidden Files and Directories	Software								
		Hidden Users	/etc/passwd and /etc/shadow								
		Hidden Window	Cached Domain Credentials								
		NTFS File Attributes	DCSync								
		Run Virtual Instance	LSA Secrets								
		VBA Stomping	LSASS Memory								
			NTDS								

1. How We Attack: MITRE ATT&CK

Credential Access 15 techniques		Discovery 27 techniques	
II	Credential Stuffing	Account Discovery (0/4)	II
	Password Cracking	Application Window Discovery	II
	Password Guessing	Browser Bookmark Discovery	II
	Browser Bookmark Discovery (T1217)	Cloud Infrastructure Discovery	II
II	Password Spraying	Cloud Service Dashboard	II
		Cloud Service	II
			II

Browser bookmarks may also highlight additional targets after an adversary has access to valid credentials, especially Credentials In Files associated with logins cached by a browser.

1. How We Attack: MITRE ATT&CK

Playbook	T1217	Browser Bookmark Discovery
Goal	1. Enumerate local browsers 2. Extract history 3. Extract passwords from browser 4. Identify often used OT control interfaces 5. Identify how the operator authenticates i.e. via SSO or local credentials	
Method	SharpWeb, Browserloot.ps1 Metasploit: post/multi/gather/firefox_creds	
ATT&CK Defense	<i>“This type of attack technique cannot be easily mitigated with preventive controls since it is based on the abuse of system features.”</i>	

1. How We Attack: MITRE ATT&CK



History:

Heatingcontrols.kplant

Browser Credentials:

XN5896 / Nioij()/&*

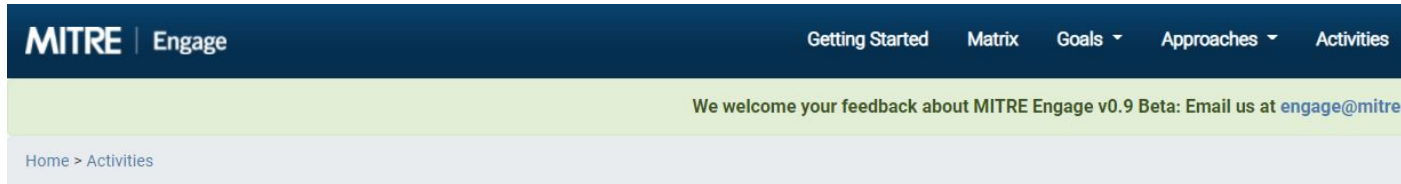


2. How Enterprises Can Defend: MITRE Engage

2. How Enterprises Can Defend: MITRE Engage

Prepare	Expose		Affect			Elicit		Understand
Planning	Collection	Detection	Prevention	Direction	Disruption	Reassurance	Motivation	Analysis
Define Exit Criteria	API Monitoring	Decoy Artifacts and Systems	Baseline	Decoy Artifacts and Systems	Decoy Artifacts and Systems	Application Diversity	Application Diversity	Distill Intelligence
Develop Threat Model	Network Monitoring	Detonate Malware	Hardware Manipulation	Detonate Malware	Isolation	Artifact Diversity	Artifact Diversity	Hotwash
Persona Creation	Software Manipulation	Network Analysis	Isolation	Email Manipulation	Network Manipulation	Burn-In	Detonate Malware	Inform Threat Model
Strategic Goal	System Activity Monitoring		Network Manipulation	Migrate Attack Vector	Software Manipulation	Email Manipulation	Information Manipulation	Refine Operation Activities
Storyboarding			Security Controls	Network Manipulation		Information Manipulation	Personas	
				Peripheral Management		Network Diversity	Network Diversity	
				Security Controls		Peripheral Management		
				Software Manipulation		Pocket Litter		

2. How Enterprises Can Defend: MITRE Engage



Decoy Artifacts and Systems

Introduce impersonations to expand the scope of a deceptive story.

Decoy Artifacts and Systems allow the defender to increase the attack surface of their environment to expose more of the deception story. Additionally, they can be used to adjust the adversary's sense of ambiguity to increase or decrease their level of uncertainty towards the environment. Investigation of these decoy artifacts may introduce a resource cost on the adversary, enable or block the adversary's intended actions, encourage or discourage a specific action or response, etc.

Decoy artifacts can take a variety of forms including credentials, accounts, files/directories, **browser** extensions/bookmarks, system processes, etc. Decoy systems can be real, virtual, or simulated. They can be presented as one of a variety of IT devices, including user workstations, servers, networking systems, IOT (embedded devices), mobile devices, etc. Regardless of form, these decoy artifacts and systems provide a variety of opportunities for the defender. For example, decoy artifacts can be used as tripwires to produce a high-fidelity alert when accessed.

Careful planning should guide the creation and deployment of these tripwires to ensure effectiveness. For example, understanding the adversary's known TTPs will highlight which resources the adversary is likely to touch, and therefore where decoy artifacts should be placed. A thorough assessment of the defender's priority cyber assets and intellectual property should guide the placement of decoy artifacts used as tripwires.

A decoy artifact can provide several means to influence adversary activity. The following examples illustrate the powerful effects decoy artifacts and systems can have on the adversary. First, by planting decoy artifacts and systems that align with known adversary TTPs, the defender can influence adversary activities. For example, if a target adversary has a capability against a specific application, the defender can place this vulnerable application in the environment to motivate the adversary to exploit the decoy.

As a second example, a defender may install AV or some other security or monitoring tool in a way that is easy for the adversary to remove. If an adversary removes the tool, they may be emboldened to act more openly believing they can't be monitored.

The defender can attempt to demotivate the adversary by strategically placing decoy artifacts. For example, a defender could place a selection of reverse engineering tools or monitoring applications on a known vulnerable target. This may sow confusion and raise ambiguity, demotivating the adversary's desire to go after that target even if it is vulnerable.

Decoy artifacts can take a variety of forms including credentials, accounts, files/directories, **browser** extensions/**bookmarks**, system processes, etc. Decoy systems can be real, virtual, or simulated.



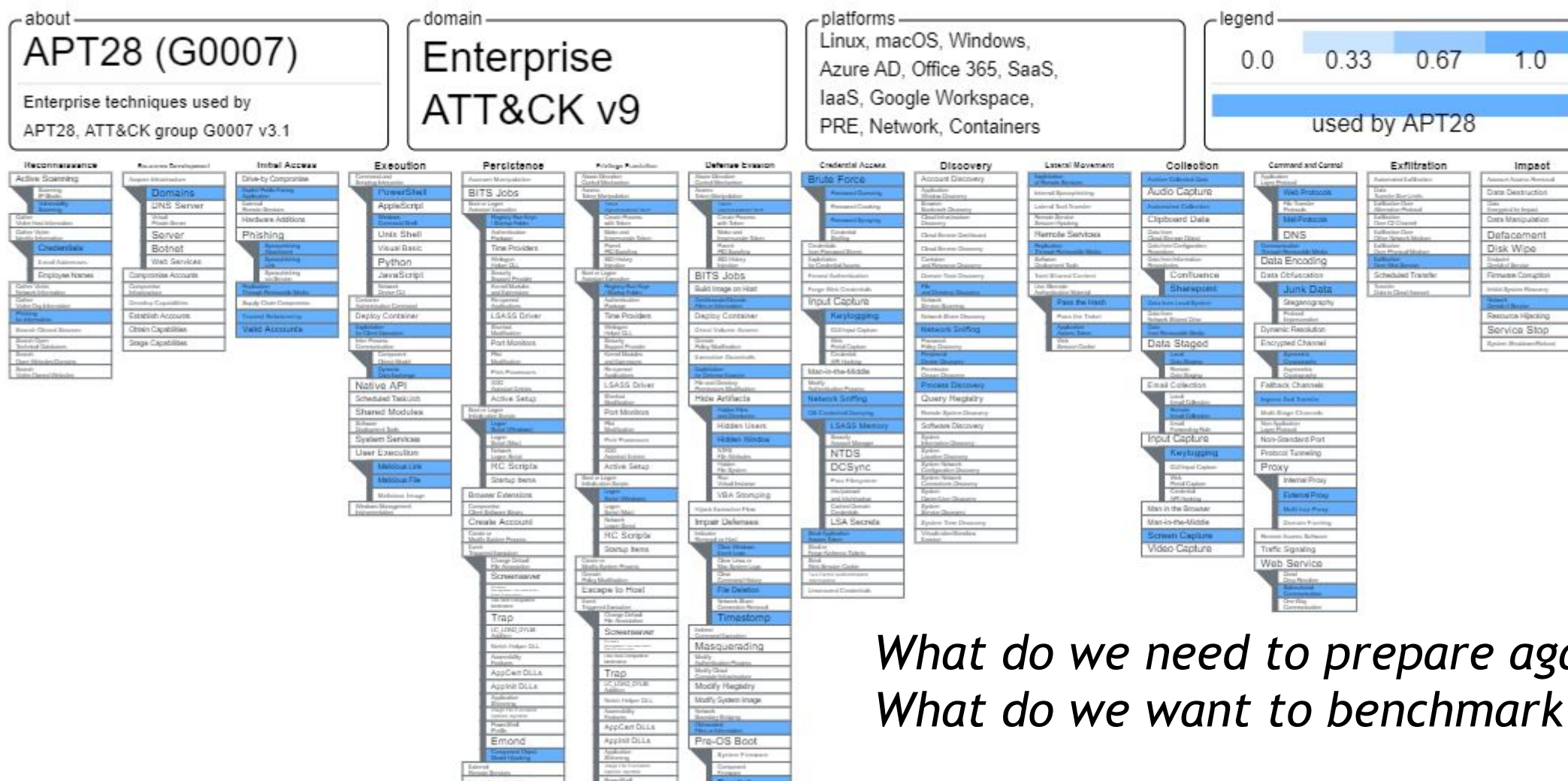
3. Adjusted Red Team Attack Playbooks

3. Adjusted Red Team Attack Playbooks



<https://encrypted-tbn0.gstatic.com/images?q=tbn:ANd9GcQtkS9MCB6oj3vdueBR1fPGOUj6D00yAFqjnQ&usqp=CAU>

3. Adjusted Red Team Attack Playbooks



*What do we need to prepare against?
What do we want to benchmark for?*

3. Adjusted Red Team Attack Playbooks

Playbook	T1217	Browser Bookmark Discovery
Goal	1. Enumerate local browsers 2. Extract history 3. Extract passwords from browser 4. Identify often used OT control interfaces 5. Identify how the operator authenticates i.e. via SSO or local credentials Do not engage before: Compare browsing history between browsers to identify honeypot URLs, i.e. a browser that only surfs to two, three high impact websites is suspicious Compare credentials from browsers against standard credentials: If they seem very different it could be a honeypot	
Method	SharpWeb, Browserloot.ps1 Metasploit: post/multi/gather/firefox_creds	
ATT&CK Defense	This type of attack technique cannot be easily mitigated with preventive controls since it is based on the abuse of system features.	
Engage	Decoy artifacts can take a variety of forms including credentials, accounts, files/directories, browser extensions/bookmarks, system processes, etc.	

3. Adjusted Red Team Attack Playbooks



History:

Heatingcontrols.kplant

Browser Credentials:

XN5896 / Nioij()/&*



History:

maintenance.kplant

Browser Credentials:

Kplant\Johnny.s / Start2021!



4. Key Takeaways

4. Key Takeaways

Use MITRE Engage to augment your Red Teaming TTPs

Understand the options the Blue Team has to defend, i.e. if a single security control is not available, it does not mean there is not defense in place

Identify Engage controls in place to derive further controls: If they have honeypot credentials in the browser, what about Active Directory?

Align your results

We are now able to better advise on remediations by citing MITRE Engage and how it would have impacted the engagement

Prepare
Planning
Define Exit Criteria
Develop Threat Model
Persona Creation
Strategic Goal
Storyboarding



[BlackHills: OPSEC Fundamentals for Remote Red Teams](#)

[X33fCon: OPSEC Obsessed](#)

[CYBV436 Counter Cyber Threat Intelligence](#)

Questions?

johannes@exploitlabs.de